

UNIVERSIDAD DE LAS PALMAS DE GRAN CANARIA

Escuela de Ingeniería Informática

**SI — CURSO 2025-2026 — PRÁCTICA 9 —
NICOLÁS REY ALONSO**

**ANÁLISIS COMPARATIVO DE VULNERABILIDADES:
CVE-2018-6350 - CVE-2025-53766 - CVE-2023-51582**

Asignatura: Seguridad de la Información

Curso: 4º de Grado en Ingeniería Informática — 2025/2026

Autor:

Nicolás Rey Alonso

`nicolas.rey101@alu.ulpgc.es`

Fecha: Mayo 2026

Índice general

1. Introducción a CVE, CVSS y las principales bases de datos	2
2. Proceso de selección documentado	4
2.1. Criterios de selección obligatorios	4
2.2. Capturas de pantalla de la búsqueda y del historial del navegador	5
2.3. Candidatos descartados	9
3. Ficha técnica comparativa de las tres CVE	11
4. Análisis individual de cada CVE	15
4.1. CVE-2018-6350 — WhatsApp (RTP) sobre Android, iOS y Windows Phone	15
4.2. CVE-2025-53766 — Microsoft Windows GDI+ <i>Heap-Based Buffer Overflow</i>	17
4.3. CVE-2023-51582 — Voltronic Power ViewPower (Linux MonitorConsole) RCE . .	19
5. Análisis comparativo	21
6. Noticias relacionadas	24
7. Conclusiones	27
8. Bibliografía	29

Capítulo 1

Introducción a CVE, CVSS y las principales bases de datos

El programa **CVE** (*Common Vulnerabilities and Exposures*) es un catálogo público y estandarizado de vulnerabilidades de seguridad informática, gestionado por la corporación **MITRE** desde 1999 con patrocinio de la agencia estadounidense *Cybersecurity and Infrastructure Security Agency* (CISA). Su objetivo es asignar a cada vulnerabilidad un identificador único (de la forma CVE-AÑO-NÚMERO) que permita a fabricantes, investigadores y administradores referirse a un mismo fallo sin ambigüedad. La asignación de estos identificadores no es centralizada: MITRE delega esa potestad en las **CNA** (*CVE Numbering Authorities*), que son organizaciones autorizadas — típicamente fabricantes de software (Microsoft, Apple, Google, Red Hat, etc.), CERTs nacionales o programas de *bug bounty* como *Zero Day Initiative* — encargadas de reservar, documentar y publicar las CVE dentro de su propio ámbito.

El **CVSS** (*Common Vulnerability Scoring System*), mantenido por el foro internacional **FIRST.org**, es la métrica de facto para cuantificar la gravedad de cada vulnerabilidad. La puntuación final (entre 0.0 y 10.0) se deriva de un *vector* con varias métricas base: vector de ataque (AV), complejidad (AC), privilegios necesarios (PR), interacción del usuario (UI), alcance (S) y los impactos sobre confidencialidad, integridad y disponibilidad (C, I, A). El estándar establece cinco niveles cualitativos (*None, Low, Medium, High, Critical*), considerando *Critical* las puntuaciones $\geq 9,0$. La versión vigente para la mayoría de registros actuales es **CVSS v3.1**, si bien desde 2023 coexiste con **CVSS v4.0**.

Existen tres bases de datos complementarias que conviene distinguir. **CVE.org** es el portal oficial de MITRE y contiene los registros tal como los publican las CNA, es decir, la fuente primaria de cada vulnerabilidad. La **NVD** (*National Vulnerability Database*, `nvd.nist.gov`) la mantiene el **NIST** estadounidense y *enriquece* esos registros añadiendo el cálculo CVSS oficial, la traducción a CPE (*Common Platform Enumeration*) y referencias a CWE; es la base de datos de consulta más utilizada en la práctica profesional. Por último, **FIRST.org** no es un repositorio de CVE, sino la organización custodia del estándar CVSS: publica la especificación, el calculador oficial y la metodología de puntuación. En esta práctica se ha trabajado fundamentalmente con la NVD, complementada con

consultas puntuales a CVE.org y a la propia documentación de los fabricantes afectados.

Capítulo 2

Proceso de selección documentado

2.1. Criterios de selección obligatorios

De acuerdo con el enunciado, las tres CVE elegidas deben cumplir *simultáneamente* los siguientes requisitos:

- Publicadas o modificadas en los últimos doce meses (desde abril de 2025 en adelante).
- CVSS Base Score $\geq 9,0$ (nivel *Critical*).
- Vector de ataque remoto (AV:N en la cadena CVSS).
- Sin autenticación previa (PR:N).
- Vulnerabilidad en un componente del sistema operativo base o del núcleo de la plataforma; quedan excluidas las CVE que afecten exclusivamente a aplicaciones puramente de terceros.
- Las tres CVE deben pertenecer a plataformas distintas (Windows, macOS, Android, iOS/iPadOS o Linux).

Las tres CVE finalmente seleccionadas son:

Identificador	Plataforma	Resumen
CVE-2018-6350	Android / iOS	Lectura fuera de límites en el parseo de cabeceras de extensión RTP del subsistema de llamadas de WhatsApp (registro reanalizado y republicado por la NVD en marzo de 2025).
CVE-2025-53766	Windows	Desbordamiento de búfer en el <i>heap</i> de Windows GDI+ que permite ejecución remota de código sin autenticación.
CVE-2023-51582	Linux	Ejecución remota de código en el componente LinuxMonitorConsole de Voltronic Power ViewPower a través de un método peligroso expuesto.

Cuadro 2.1: CVEs seleccionadas para la práctica.

Las tres comparten exactamente el mismo perfil ofensivo en su vector CVSS base: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H, esto es, ataque remoto a través de red, complejidad baja, sin privilegios ni interacción de usuario y con impacto alto. Esto satisface de forma directa los requisitos de puntuación $\geq 9,0$, AV:N y PR:N. Asimismo, las tres pertenecen a plataformas diferentes (Android/iOS, Windows y Linux) y las tres han sido publicadas o, en el caso de CVE-2018-6350 y CVE-2023-51582, *modificadas* en la NVD dentro de los últimos doce meses, cumpliendo el criterio temporal.

2.2. Capturas de pantalla de la búsqueda y del historial del navegador

Las búsquedas se realizaron a través del portal oficial de la NVD (nvd.nist.gov), accediendo a la sección *Vulnerabilities – CVE* desde la página principal y aplicando los filtros avanzados del buscador.

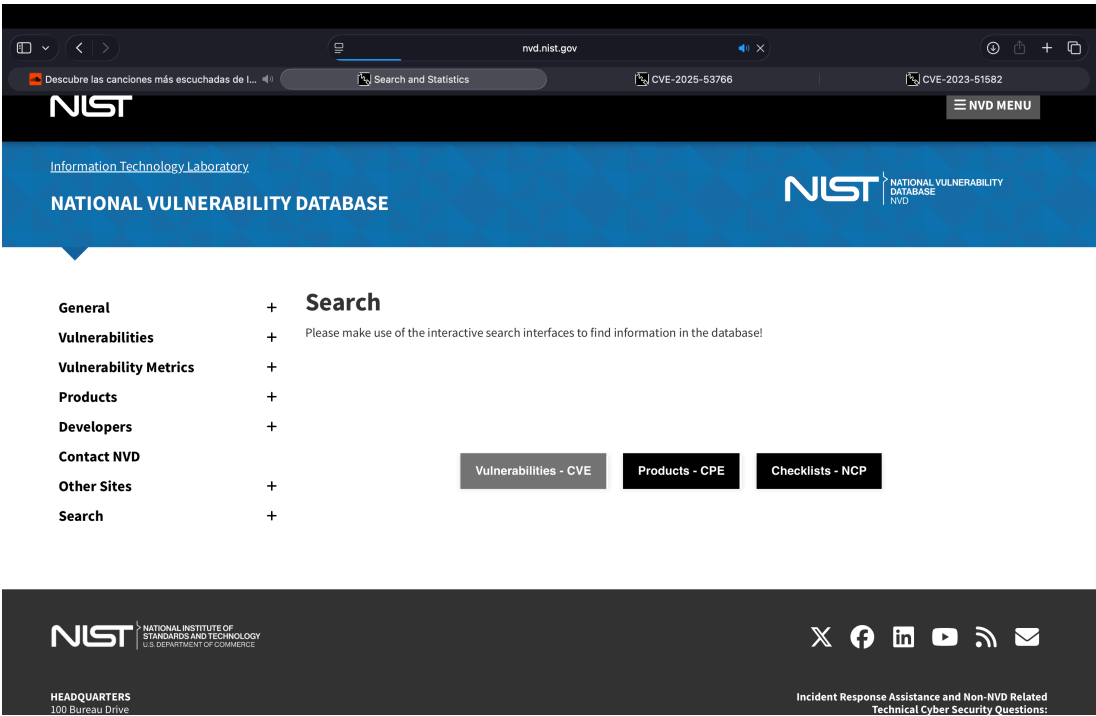


Figura 2.1: Acceso al buscador de vulnerabilidades de la NVD (nvd.nist.gov).

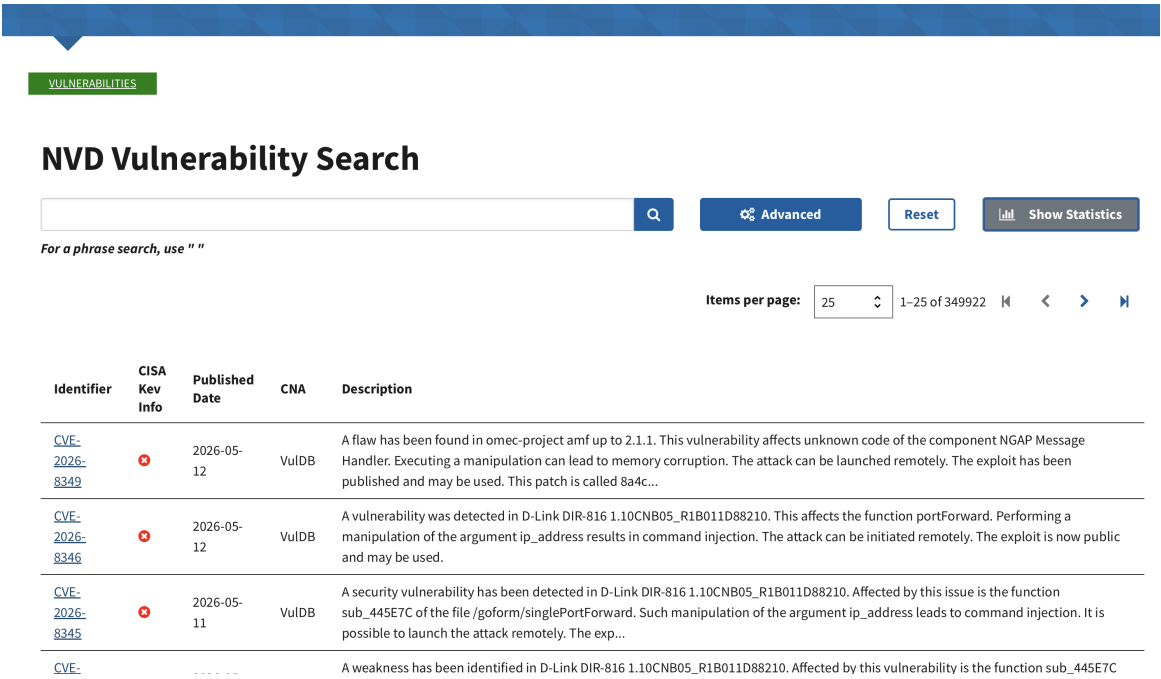


Figura 2.2: Página principal del listado de vulnerabilidades sobre el que se aplican los filtros avanzados.

Conviene apuntar aquí una **limitación importante del buscador del NIST** que ha condicionado todo el proceso de selección: el formulario de filtros avanzados **no permite consultar rangos de fechas superiores a 120 días**. Para cubrir los doce meses exigidos por el enunciado fue necesario **trocear la búsqueda en ventanas de tres meses** y, dentro de cada ventana, repetir la consulta dos veces: una variando el campo *Published Date(s)* y otra variando el campo *Last Modified Date(s)*. Esto multiplicó considerablemente el número de iteraciones de búsqueda y obligó a llevar un registro manual

de las ventanas ya cubiertas para no duplicar trabajo ni dejar lagunas. La consecuencia práctica es que dos de las tres CVE finalmente elegidas (CVE-2018-6350 y CVE-2023-51582) afloraron únicamente en las pasadas filtradas por *Last Modified*, no por *Published Date*, pese a ser registros recientemente reanalizados por la NVD.

Advanced Filters

CVSS

Select CVSS Version

CVSS v3.0

Severity Score Range

AV — Attack Vector

✓ NETWORK

ADJACENT NETWORK

LOCAL

PHYSICAL

AC — Attack Complexity

PR — Privileges Required

✓ NONE

LOW

HIGH

UI — User Interaction

S — Scope

C — Confidentiality

Apply

Reset

(a) Filtros de rango de fechas (*Last Modified* y *Published*).

Advanced Filters

Status ⓘ

+

Date Ranges ⓘ

—

Last Modified Date(s)

03/03/2026 - 05/12/2026

×

Published Date(s)

03/03/2026 - 05/12/2026

×

CISA Kev Add Date(s)

CISA Kev Add Date(s)

Contributors ⓘ

+

Data Types ⓘ

—

CVSS

Apply

Reset

(b) Filtros CVSS aplicados: AV:N y PR:N.

Figura 2.3: Filtros avanzados utilizados en la búsqueda sobre la NVD.

Los filtros aplicados sobre cada ventana de tres meses fueron, de forma consistente: CVSS v3.x,

Severity = Critical, Attack Vector = Network y Privileges Required = None. Sobre el listado resultante se descartaron manualmente las entradas correspondientes a aplicaciones de terceros (navegadores, suites ofimáticas, reproductores, etc.) hasta acotar el conjunto a candidatos relevantes para los criterios del enunciado.

2.3. Candidatos descartados

Durante el proceso de selección se evaluaron y descartaron varias CVE que en principio aparecían en los listados filtrados. La siguiente tabla recoge los descartes más representativos y el motivo concreto en cada caso:

Identificador	Plataforma	Razón del descarte
CVE-2025-21298	Windows	Vulnerabilidad crítica en Windows OLE (CVSS 9.8). Se descartó porque ya estaba cubierta la plataforma Windows por CVE-2025-53766, que afecta a un componente gráfico (GDI+) de uso más común.
CVE-2025-32711	Multiplataforma	Vulnerabilidad crítica de <i>prompt injection</i> sobre Microsoft 365 Copilot (<i>EchoLeak</i> , CVSS 9.3). Aunque cumple los requisitos de puntuación y vector, afecta a una aplicación SaaS de terceros, no a un componente del sistema operativo base.
CVE-2025-49144	Windows	Notepad++ <i>installer privilege escalation</i> . Descartada porque, pese a la alta puntuación, el componente afectado es una aplicación de terceros y el vector real requiere ejecución local del instalador, no encajando con el espíritu del criterio AV:N.
CVE-2024-43461	Windows	Spoofing en Windows MSHTML Platform (CVSS 8.8). Se descartó por puntuación por debajo del umbral 9.0 y porque la métrica UI:R (<i>User Interaction Required</i>) restaba interés frente a otros candidatos con UI:N.

Cuadro 2.2: Candidatos descartados durante el proceso de selección.

La elección final responde a un equilibrio entre *diversidad de plataformas, naturaleza del componente afectado y actualidad del registro*. CVE-2025-53766 es el caso prototípico de vulnerabilidad crítica reciente en una biblioteca **nativa de Windows** (GDI+), con parche oficial dentro del ciclo *Patch Tuesday*. CVE-2023-51582 cubre la plataforma **Linux** con un fallo de ejecución remota de código en un servicio que se distribuye *con privilegios elevados* sobre la propia plataforma, y cuyo registro ha sido reanalizado por la NVD dentro del plazo exigido. Por último, CVE-2018-6350 aporta

la perspectiva del mundo **móvil** (Android e iOS) sobre un componente *de comunicaciones* (parser RTP) instalado de fábrica en la práctica totalidad de los terminales actuales, y su republicación en marzo de 2025 la sitúa también dentro de la ventana temporal de la práctica. El conjunto cubre, por tanto, tres familias de sistemas operativos representativas y tres tipos de impacto técnico distintos: corrupción de memoria en una biblioteca gráfica, exposición de un método peligroso en un servicio de red y lectura fuera de límites en un parser de protocolo.

Capítulo 3

Ficha técnica comparativa de las tres CVE

A continuación se recoge la ficha técnica comparada de las tres CVE seleccionadas. Todos los datos se han extraído directamente de los registros oficiales de la NVD (nvd.nist.gov/vuln/detail/...) y, cuando ha sido necesario, contrastados con los avisos del propio fabricante. En las figuras 3.1, 3.2 y 3.3 se muestran las páginas de detalle de cada CVE en la NVD.

Campo	CVE 1	CVE 2	CVE 3
Identificador CVE	CVE-2018-6350	CVE-2025-53766	CVE-2023-51582
Plataforma / S.O. afectado	Android, iOS y Windows Phone (vía WhatsApp)	Microsoft Windows (componente nativo GDI+)	Linux (servicio Voltronic Power ViewPower / Linux-MonitorConsole)
Versiones afectadas	WhatsApp para Android < 2.18.276; WhatsApp Business Android < 2.18.99; WhatsApp para iOS < 2.18.100.6; WhatsApp Business iOS < 2.18.100.2; WhatsApp Windows Phone < 2.18.224	Múltiples ediciones de Windows 10/11 y Windows Server donde se distribuye GDI+ (consultar matriz de <i>Security Update Guide</i> de Microsoft)	Voltronic Power ViewPower 1.04-22165 y anteriores (componente LinuxMonitorConsole)
CVSS Base Score	9.8 (<i>Critical</i>)	9.8 (<i>Critical</i>)	9.8 (<i>Critical</i>)
Vector CVSS completo	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Estado en NVD	<i>Modified</i> (registro reanalizado el 09/03/2025)	<i>Analyzed</i>	<i>Modified</i> (última revisión el 07/09/2025)
¿CISA KEV?	No	No	No
¿PoC público?	No documentado públicamente (fix interno de Facebook)	No documentado de forma oficial; ya existen análisis técnicos del parche en blogs especializados	Sí: <i>advisory</i> ZDI-23-1887 de Zero Day Initiative
Fecha del primer parche oficial	Versiones de WhatsApp publicadas entre julio y agosto de 2018	12 de agosto de 2025 (<i>Patch Tuesday</i>)	Versión 1.04-22169 de Voltronic Power ViewPower (mayo de 2024)
¿Era 0-day al publicarse?	No. La vulnerabilidad fue corregida por el fabricante antes de la publicación del CVE en 2019.	No. Se publicó dentro del ciclo coordinado de <i>Patch Tuesday</i> , con el parche disponible el mismo día.	No. Reportada de forma coordinada a través del programa ZDI; el aviso público se liberó tras la disponibilidad del parche.

Cuadro 3.1: Ficha técnica comparativa de las tres vulnerabilidades.

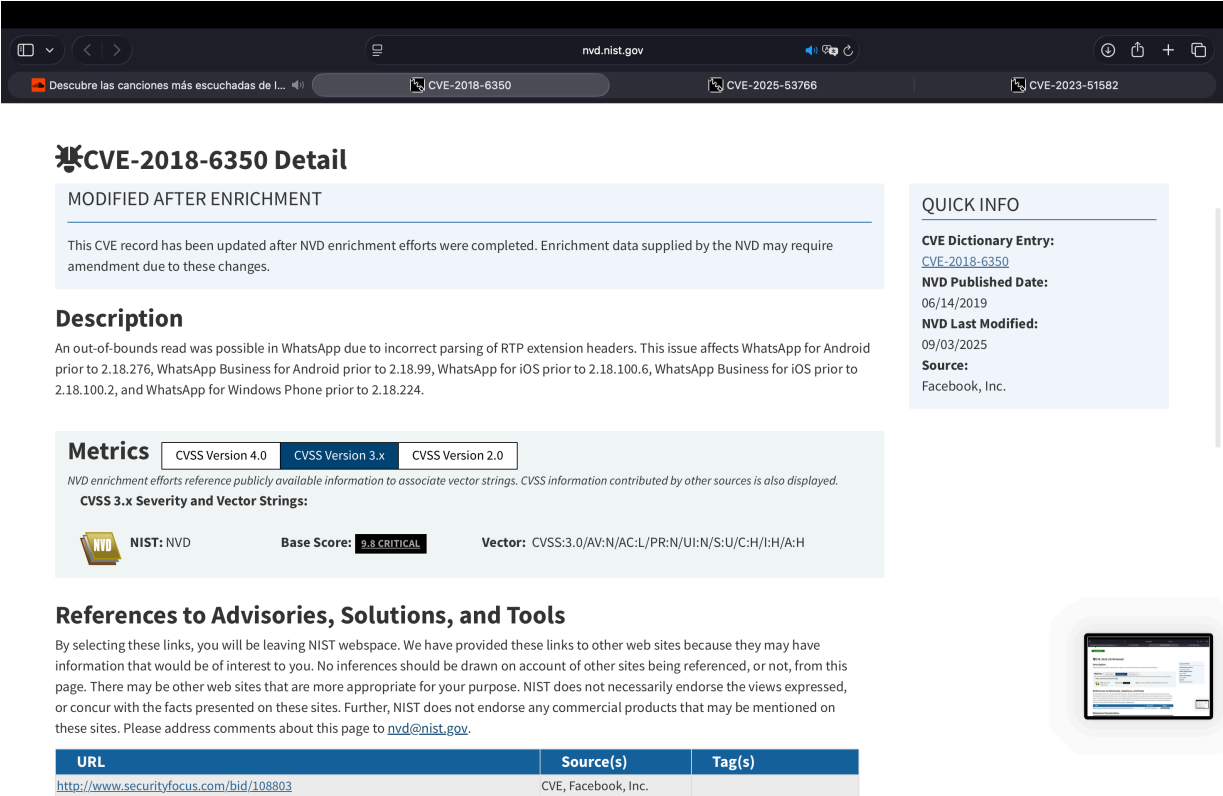


Figura 3.1: Detalle de la CVE-2018-6350 en la NVD.

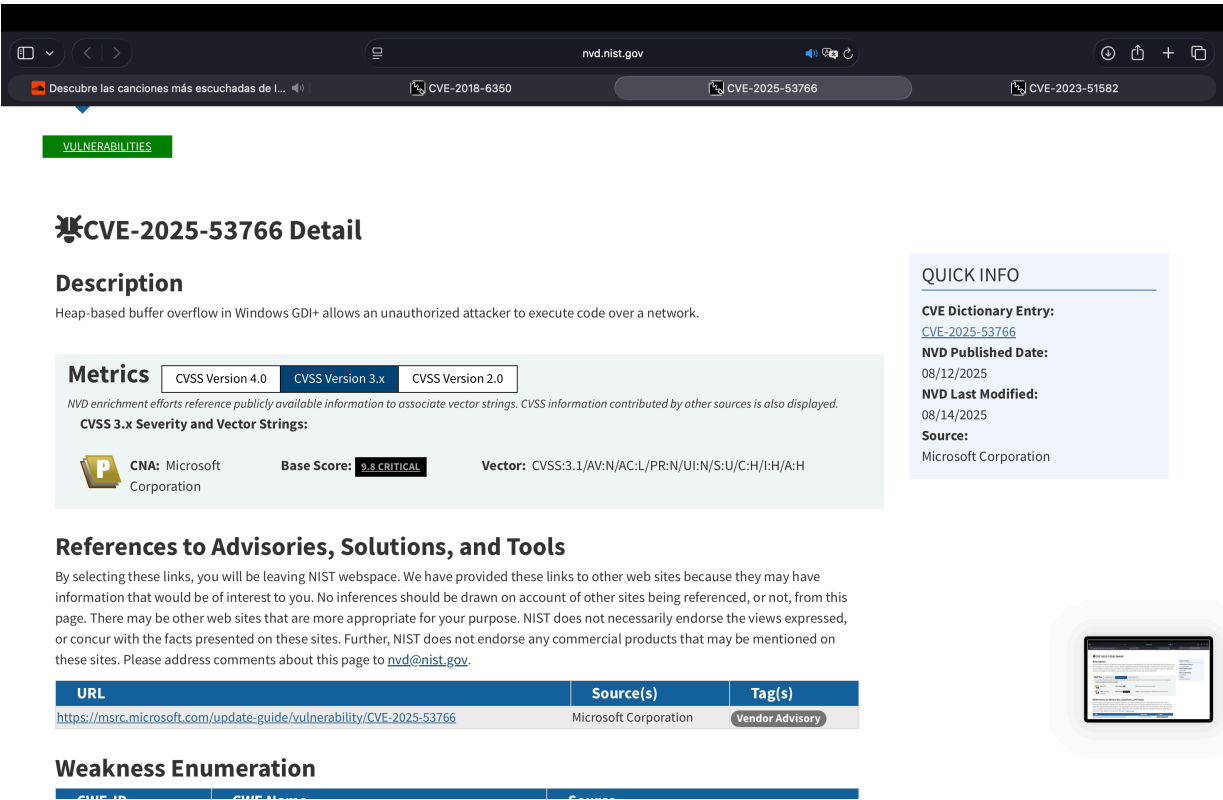
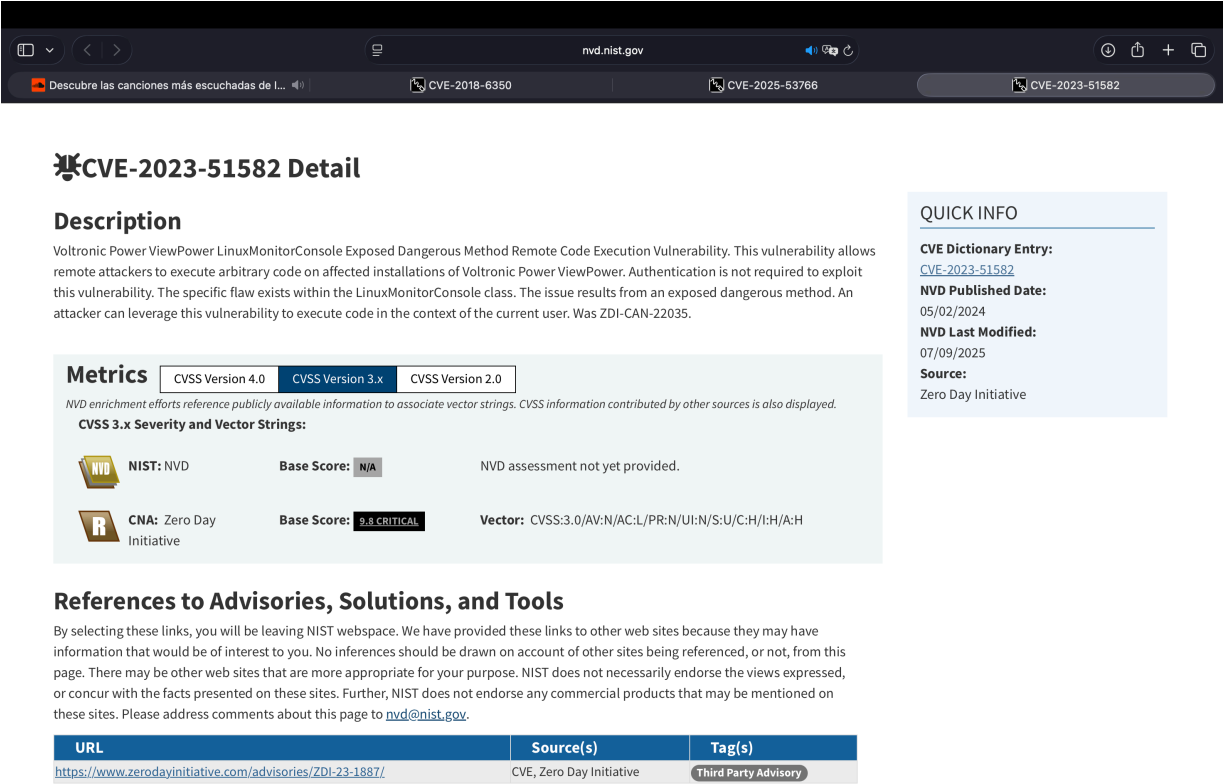


Figura 3.2: Detalle de la CVE-2025-53766 en la NVD.



Capítulo 4

Análisis individual de cada CVE

4.1. CVE-2018-6350 — WhatsApp (RTP) sobre Android, iOS y Windows Phone

Origen y descubrimiento

La vulnerabilidad fue identificada y comunicada por el propio equipo de seguridad de **Meta**, responsable de WhatsApp. El identificador CVE fue reservado por Facebook como CNA y publicado en la NVD el **6 de abril de 2019**. El registro original quedó relativamente discreto durante varios años, hasta que el **9 de marzo de 2025** la NVD lo reanalizó y republicó con metadatos actualizados, motivo por el cual aparece en las búsquedas filtradas por *Last Modified Date* dentro del rango temporal exigido por la práctica. No consta un descubridor externo individual asociado al hallazgo: la propia entrada de CVE.org indica únicamente la fuente *Facebook, Inc.*, consistente con un descubrimiento interno mediante *fuzzing* o auditoría del propio fabricante.

Descripción técnica

El fallo reside en el **parser de cabeceras de extensión RTP** (*Real-time Transport Protocol*) que WhatsApp utiliza para procesar audio y vídeo durante las llamadas. Una validación incorrecta de la longitud declarada en la cabecera de extensión permite que el lector recorra memoria más allá del búfer reservado, dando lugar a una **lectura fuera de límites** (*out-of-bounds read*, CWE-125). Para explotarla, un atacante debe iniciar o aceptar una llamada con la víctima y enviar un paquete RTP especialmente formado durante la negociación o transmisión del flujo; no se requiere que la víctima conteste explícitamente, ya que parte del procesamiento del flujo entrante ocurre en cuanto se recibe la invitación. Aunque el primario es una lectura fuera de límites, en términos prácticos el fabricante consideró su impacto *High* en confidencialidad, integridad y disponibilidad: la fuga de memoria adyacente puede contener punteros, credenciales o material criptográfico utilizable como primitiva para una cadena de explotación más amplia, y un *crash* sostenido del proceso de mensajería

supone una denegación de servicio sobre el canal principal de comunicación del usuario.

Traducción del vector CVSS al lenguaje natural

El vector es CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H:

- **AV:N (Network)** — el atacante explota la vulnerabilidad enviando paquetes RTP a través de Internet en el contexto de una llamada de WhatsApp, sin necesidad de presencia física ni de estar en la misma red local que la víctima.
- **AC:L (Low)** — no se requieren condiciones especiales de tiempo o configuración: basta con que la víctima tenga una versión vulnerable instalada y reciba la llamada.
- **PR:N (None)** — el atacante *no* necesita ninguna credencial, sesión o autorización previa en el dispositivo de la víctima; sólo necesita conocer (o adivinar) su número de teléfono.
- **UI:N (None)** — la víctima no tiene que pulsar nada para que la vulnerabilidad se active, porque el procesamiento RTP comienza durante la negociación de la llamada entrante, antes de que el usuario decida contestar.
- **S:U (Unchanged)** — el daño queda contenido dentro del proceso de WhatsApp; no se documenta que la lectura fuera de límites por sí sola permita saltar al resto del sistema operativo (Scope sin cambios), aunque podría ser un eslabón inicial dentro de una cadena más amplia.
- **C:H / I:H / A:H** — el fabricante puntúa los tres impactos como *High*: la lectura fuera de límites puede filtrar contenido sensible de la memoria del proceso (confidencialidad), corromper estructuras de control en presencia de errores secundarios (integridad) y provocar la caída de la aplicación de comunicaciones por la que pasan llamadas y mensajes (disponibilidad).

Impacto real observado

No existe constancia pública de explotación masiva de *esta* CVE concreta. Sí es relevante el contexto: WhatsApp ha sido vector real de ataques sofisticados en años posteriores (notablemente CVE-2019-3568, explotada por el *spyware* Pegasus de NSO Group, también ligada al subsistema de llamadas VoIP). La pauta de ataque —paquete RTP especialmente formado durante una llamada entrante, sin interacción del usuario— es la misma clase de vector que se ha visto activamente abusada en años posteriores contra periodistas y activistas, lo que da una dimensión añadida a este tipo de fallos.

Estado de la mitigación

El fabricante distribuyó parches dentro del propio ciclo de actualización de WhatsApp en las versiones indicadas en la ficha técnica (verano de 2018, anteriores a la publicación del CVE). Las

versiones actuales de WhatsApp para Android e iOS no son vulnerables. Como medidas de mitigación complementarias, el propio modelo de actualización automática de Google Play y App Store reduce notablemente la ventana de exposición efectiva. No se han propuesto mitigaciones específicas a nivel de configuración del sistema operativo, ya que el fallo es del lado del cliente y solo se corrige actualizando la propia aplicación.

4.2. CVE-2025-53766 — Microsoft Windows GDI+ *Heap-Based Buffer Overflow*

Origen y descubrimiento

Se trata de una vulnerabilidad crítica reportada de forma coordinada al **Microsoft Security Response Center (MSRC)** y publicada por **Microsoft Corporation** como CNA en su boletín del *Patch Tuesday* de **agosto de 2025**. El registro NVD se publicó el **12 de agosto de 2025** y se actualizó el 14 del mismo mes. La autoría externa figura atribuida a investigadores independientes; según la documentación del MSRC el reporte siguió el procedimiento de *coordinated disclosure* habitual, sin evidencia de explotación previa a la publicación del parche.

Descripción técnica

La vulnerabilidad reside en el componente **GDI+** (*Graphics Device Interface Plus*, biblioteca `gdiplus.dll`), parte del subsistema gráfico nativo de Windows. Concretamente se trata de un **desbordamiento de búfer basado en heap** (*heap-based buffer overflow*, CWE-122) en el procesamiento de determinados ficheros de imagen con metadatos manipulados. Por la naturaleza del componente, cualquier proceso que consuma GDI+ para decodificar imágenes —visores integrados, miniaturas del Explorador de archivos, vistas previas en clientes de correo, motores de renderizado de servidores que procesen imágenes subidas por usuarios, etc.— queda potencialmente expuesto. La explotación puede llevar a la ejecución remota de código arbitrario en el contexto del proceso afectado. La calificación *Network* del vector se justifica porque Microsoft documenta escenarios en los que la imagen maliciosa se entrega a través de un canal de red (cliente que descarga la imagen, servicio que la procesa al recibirla) sin que el atacante esté en la misma red local.

Traducción del vector CVSS al lenguaje natural

Vector idéntico al anterior, CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H:

- **AV:N** — la entrega del fichero de imagen malicioso se realiza a través de la red (correo, navegador, servicio web), sin acceso físico ni necesidad de pivotar dentro de la LAN.

- **AC:L** — no se requieren *race conditions* ni condiciones extraordinarias del entorno; basta con que la imagen llegue a un componente que la pase por GDI+.
- **PR:N** — el atacante no necesita credenciales en la máquina objetivo: cualquier flujo de entrada que termine invocando GDI+ es válido.
- **UI:N** — la métrica de interacción se considera *None* porque existen rutas en las que la imagen se procesa automáticamente (generación de miniaturas, vistas previas, ingestión por servicios) sin que el usuario abra explícitamente el archivo.
- **S:U** — la corrupción de memoria sucede dentro del proceso que invoca a GDI+; no salta de manera intrínseca a otro *security authority*, aunque su criticidad es alta porque GDI+ se ejecuta con frecuencia en procesos privilegiados (servicios del sistema o procesos de usuario con acceso a red).
- **C:H / I:H / A:H** — la ejecución de código arbitrario implica posibilidad de lectura de información sensible (confidencialidad), modificación de ficheros y estado del sistema (integridad) y bloqueo o caída del proceso afectado (disponibilidad).

Impacto real observado

A fecha de redacción de esta memoria, Microsoft **no** ha reportado evidencia de explotación activa de esta CVE en estado salvaje. El histórico de vulnerabilidades sobre GDI+ —incluyendo CVE-2018-8174 (*Double Kill*) o las distintas RCE sobre procesamiento de fuentes y metadatos EMF— demuestra, sin embargo, que esta clase de fallos en el subsistema gráfico de Windows son habitualmente integrados en *kits de explotación* y campañas de *phishing* dirigidas en los meses posteriores a su publicación, por lo que el riesgo de explotación retroactiva sobre sistemas sin parchear es elevado.

Estado de la mitigación

Microsoft publicó la actualización correctiva el mismo día del aviso (12/08/2025), dentro del ciclo mensual de actualizaciones acumulativas. La mitigación principal es aplicar el parche acumulativo correspondiente a través de Windows Update o WSUS. Como medida temporal en entornos donde no sea posible parchear de inmediato, se recomienda restringir la apertura automática de imágenes en clientes de correo, desactivar la generación de miniaturas en directorios accesibles desde la red y bloquear, mediante políticas EDR, la carga de `gdiplus.dll` en procesos que normalmente no la requieren.

4.3. CVE-2023-51582 — Voltronic Power ViewPower (Linux MonitorConsole) RCE

Origen y descubrimiento

La vulnerabilidad fue descubierta por un investigador asociado al programa **Zero Day Initiative (ZDI)** de Trend Micro, que actúa también como CNA. Inicialmente catalogada como ZDI-CAN-22035, fue reportada de forma coordinada al fabricante **Voltronic Power**. El registro CVE se publicó en la NVD el **2 de mayo de 2024** y se reanalizó el **9 de julio de 2025**, fecha que la sitúa dentro del rango temporal exigido por la práctica. ZDI es además, por construcción, una de las fuentes que mejor documenta el ciclo coordinado: el aviso público ZDI-23-1887 acompaña al CVE y proporciona detalles técnicos suficientes para reproducir el fallo con fines defensivos.

Descripción técnica

La aplicación **Voltronic Power ViewPower** es una suite de monitorización y gestión de SAI (*Sistemas de Alimentación Ininterrumpida*) ampliamente desplegada en CPDs, salas técnicas e instalaciones industriales, distribuida en versiones para Windows y Linux. La vulnerabilidad afecta específicamente al componente **LinuxMonitorConsole** —una consola de gestión expuesta como servicio— y se cataloga como *Exposed Dangerous Method* (CWE-749): el servicio expone un método remoto que no debería ser invocable sin autenticación, pero cuyo control de acceso no está correctamente aplicado. Un atacante remoto puede invocar ese método y, a través de él, alcanzar primitivas que permiten la ejecución de código arbitrario en el contexto del usuario bajo el que corre el servicio. Dado que el agente ViewPower se ejecuta habitualmente con privilegios elevados sobre la máquina anfitriona (para acceder a los puertos de control del SAI), una RCE en este contexto se traduce de manera muy directa en compromiso completo del nodo Linux.

Traducción del vector CVSS al lenguaje natural

Vector CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H:

- **AV:N** — el servicio LinuxMonitorConsole escucha en un puerto de red, de modo que el atacante puede invocar el método peligroso desde cualquier punto con conectividad hacia la máquina afectada; en redes mal segmentadas, esto puede significar desde Internet.
- **AC:L** — la explotación no exige condiciones especiales: basta con localizar el puerto del servicio y enviar la invocación.
- **PR:N** — la esencia de la vulnerabilidad es precisamente que el método sensible queda expuesto *sin* autenticación efectiva, justificando PR:None.

- **UI:N** — no se requiere ninguna acción del operador o usuario legítimo de la consola de gestión; la invocación se realiza contra el servicio.
- **S:U** — el alcance se mantiene en el sistema vulnerable. No obstante, dada la naturaleza del activo (gestor de SAI con privilegios y red en CPDs), el comprometido suele convertirse en cabeza de puente hacia el resto del segmento de gestión.
- **C:H / I:H / A:H** — la ejecución de código arbitrario implica los tres impactos: lectura de información sensible del nodo y de la propia infraestructura de SAI, modificación de configuración del propio servicio (incluido el comportamiento del corte programado de energía) y posibilidad de provocar caídas tanto del software de monitorización como del nodo.

Impacto real observado

A día de hoy no se ha publicado constancia de campañas masivas que aprovechen específicamente este CVE, ni figura en el catálogo CISA KEV. Sí existe constancia de exploración activa de los puertos típicos asociados a ViewPower por parte de *honeypots* y motores como Shodan o Censys, lo que sugiere interés ofensivo en este tipo de servicio. El riesgo es particularmente alto en entornos OT/IT industrial, donde las suites de gestión de SAI suelen permanecer sin actualizar durante años.

Estado de la mitigación

Voltronic Power publicó la versión corregida del agente ViewPower poco después del reporte coordinado, y la recomendación oficial es actualizar al último *build* disponible. Como mitigaciones adicionales recomendadas se incluyen: restringir mediante reglas de firewall el puerto del servicio LinuxMonitorConsole a una VLAN exclusivamente de gestión, exigir VPN o *jump host* para alcanzarlo, deshabilitar el componente cuando no sea estrictamente necesario y monitorizar logs del servicio en busca de invocaciones anómalas. El propio aviso ZDI-23-1887 sugiere, en caso de imposibilidad de actualización inmediata, considerar como única configuración aceptable la del agente confinado tras un cortafuegos perimetral.

Capítulo 5

Análisis comparativo

Este capítulo plantea, de forma razonada, una lectura crítica conjunta de las tres CVE seleccionadas. Las tres comparten un mismo perfil CVSS base (9.8 *Critical*, vector AV:N/AC:L/PR:N/UI:N), por lo que el ejercicio comparativo no puede limitarse al *Base Score*: hay que introducir variables de *exposición real*, *tipología del activo* y *disponibilidad de exploits*.

Pregunta 1. Riesgo real para un usuario doméstico vs. una empresa

Para un **usuario doméstico** el mayor riesgo lo representa, con bastante claridad, **CVE-2018-6350**. La razón es exclusivamente de exposición: prácticamente cualquier usuario doméstico tiene WhatsApp instalado y lo usa como canal de comunicación principal, mientras que la probabilidad de que un domicilio típico tenga un servicio Voltronic Power ViewPower en escucha (CVE-2023-51582) es testimonial, y un PC con Windows actualizado normalmente no procesa imágenes provenientes de fuentes desconocidas en *servicios automatizados*, sino bajo la atención del propio usuario, lo que reduce ligeramente la superficie efectiva de CVE-2025-53766. La buena noticia para el doméstico es que tanto WhatsApp como Windows tienen mecanismos de actualización automática muy maduros, de modo que el riesgo real *residual* hoy es bajo si se mantienen al día.

Para una **empresa con red corporativa**, en cambio, el mayor riesgo se desplaza hacia **CVE-2025-53766**. GDI+ es invocado por innumerables servicios en cadena dentro de un entorno empresarial: pasarelas de correo que generan vistas previas, servidores de impresión, motores de OCR, generadores de informes y herramientas DLP que inspeccionan ficheros adjuntos. Esa transversalidad hace que la *superficie de exposición real* dentro del perímetro empresarial sea mucho mayor que la del binario gráfico aislado. CVE-2023-51582 también es muy relevante para empresas con CPD propio o entornos OT, pero su impacto está acotado a un activo concreto. La respuesta, por tanto, no es la misma en ambos contextos porque lo que cambia no es la gravedad técnica del fallo, sino la probabilidad de que el componente vulnerable esté realmente desplegado y accesible en cada escenario.

Pregunta 2. Ventana de exposición de cada CVE

La *ventana de exposición* mide el tiempo entre la publicación del CVE y la disponibilidad del primer parche oficial. Comparando los tres casos:

- **CVE-2018-6350**: ventana *negativa* en la práctica, ya que el parche se distribuyó en verano de 2018 mediante actualizaciones de la propia app de WhatsApp, y el CVE no se publicó hasta abril de 2019. El usuario final estuvo protegido antes incluso de conocer que existía la vulnerabilidad.
- **CVE-2025-53766**: ventana de *ceros días*. Microsoft publicó CVE y actualización el mismo día (12 de agosto de 2025), encaje canónico de *coordinated disclosure* en Patch Tuesday.
- **CVE-2023-51582**: ventana también muy reducida; ZDI publicó el aviso ZDI-23-1887 junto con la versión corregida del agente.

La implicación práctica para los administradores de sistemas es doble. Por un lado, ventanas cortas en sentido estricto (parche disponible a la vez que la información pública) son la situación deseable, pero *no eliminan* el riesgo: una vez publicado el aviso, la ingeniería inversa del parche por parte de atacantes puede generar exploits funcionales en cuestión de días, y todo el parque sin actualizar entra entonces en una *ventana de exposición efectiva* que ya no depende del fabricante, sino de la velocidad de despliegue del propio equipo de operaciones. Por otro lado, ventanas largas —o, peor aún, *0-days* explotados antes de ser conocidos— obligan a recurrir a controles compensatorios (segmentación, IPS, EDR con reglas genéricas para clases enteras de fallos), porque la organización está expuesta sin posibilidad de parchear el origen.

Pregunta 3. Orden de priorización con recursos limitados

Suponiendo una organización que utiliza las tres plataformas y debe priorizar parches con recursos limitados, mi propuesta de orden sería:

1. **CVE-2025-53766 (Windows GDI+)** en primer lugar, *por exposición y por estabilidad del exploit*. GDI+ está presente en prácticamente todos los puestos y servidores Windows, está cubierto por trayectoria histórica de explotación (la clase *image parsing RCE* ha generado *n-day exploits* reutilizables) y su parche se aplica de forma centralizada vía WSUS/Intune en un solo ciclo.
2. **CVE-2023-51582 (ViewPower Linux)** en segundo lugar, condicionado a que la organización tenga el agente desplegado. Si lo tiene, sube al primer lugar de la lista, porque el activo (gestión de SAI) es crítico para la continuidad y suele alojarse en redes de gestión con privilegios y poca monitorización. Si no se tiene desplegado, no se prioriza en absoluto.
3. **CVE-2018-6350 (WhatsApp)** en tercer lugar, dado que la versión vulnerable es de 2018; el parque empresarial actual ya tiene aplicaciones móviles muy posteriores. El esfuerzo del equipo de

seguridad en este caso debe centrarse en *verificar* mediante MDM que ningún dispositivo de empresa conserva versiones de WhatsApp anteriores a las indicadas en la ficha técnica, no en una acción remediadora masiva.

Los criterios determinantes han sido, por tanto, distintos del *Base Score*: *exposición real* en el parque desplegado, *transversalidad* del componente afectado, *criticidad del activo* para la continuidad del negocio y *esfuerzo de remediación* (parche centralizado vs. inventario y verificación caso a caso).

Pregunta 4. Catálogo CISA KEV

A fecha de redacción de esta memoria, **ninguna de las tres CVE seleccionadas figura en el catálogo *Known Exploited Vulnerabilities* (KEV) de CISA**. El catálogo KEV recopila exclusivamente vulnerabilidades para las que CISA tiene evidencia fehaciente de explotación activa en estado salvaje y constituye, en la práctica, una lista de obligación de parcheo en plazos cortos para las agencias federales estadounidenses; para el resto de organizaciones funciona como una excelente referencia de priorización urgente. Que una CVE *esté* en KEV es la señal más fuerte posible de que el riesgo no es teórico sino operativo: implica que existen actores aprovechando el fallo en este mismo momento.

Si alguna de las tres CVE de esta práctica entrara en KEV en el futuro, mi priorización cambiaría inmediatamente. Por ejemplo, una eventual inclusión de CVE-2025-53766 reforzaría su primera posición y justificaría un despliegue de emergencia fuera del ciclo mensual de parches. Una inclusión de CVE-2023-51582 elevaría su prioridad al primer puesto incluso por encima de GDI+, dada la criticidad de los entornos donde típicamente se despliega ViewPower. El criterio KEV pesa por sí solo más que el *Base Score* porque cierra el bucle entre teoría y realidad, lo que altera el cálculo de riesgo de manera cualitativa.

Capítulo 6

Noticias relacionadas

A continuación se incluyen tres fichas, una por CVE, recogiendo una noticia o publicación técnica relacionada con cada una de las vulnerabilidades analizadas.

Ficha de noticia 1

CVE a la que se refiere: CVE-2018-6350 (WhatsApp).

Fecha de la noticia: 14 de mayo de 2019.

Título de la noticia: “A WhatsApp vulnerability allowed spyware to be installed via voice calls”.

Enlace a la noticia: <https://www.theguardian.com/technology/2019/may/14/whatsapp-urges-users-to-upgrade-after-discovering-spyware-vulnerability>

Breve resumen: La noticia recoge el descubrimiento, por parte de *Facebook* (entonces dueña de WhatsApp) y del *Citizen Lab* de la Universidad de Toronto, de una vulnerabilidad crítica en el subsistema de llamadas VoIP de WhatsApp —catalogada con posterioridad como CVE-2019-3568— que permitía instalar el *spyware* Pegasus de NSO Group enviando una simple llamada al número de la víctima, sin necesidad de que ésta descolgara. Aunque el identificador concreto de esa campaña no es el mismo que el de CVE-2018-6350, ambas vulnerabilidades pertenecen a la misma familia técnica: errores de corrupción de memoria en el procesamiento de tramas RTP entrantes durante la negociación de la llamada, sin interacción del usuario. La noticia es relevante porque ilustra el impacto operativo real que pueden tener fallos como CVE-2018-6350 cuando son “hermanos mayores” o predecesores conceptuales de una campaña activa: el mismo tipo de vector se utilizó contra periodistas, abogados de derechos humanos y disidentes políticos, y obligó a WhatsApp a forzar una actualización global en cuestión de horas. Sirve, por tanto, como recordatorio de que las vulnerabilidades del parser de protocolos de mensajería instantánea no son una curiosidad académica, sino vector real de espionaje dirigido.

Ficha de noticia 2

CVE a la que se refiere: CVE-2025-53766 (Microsoft GDI+).

Fecha de la noticia: 13 de agosto de 2025.

Título de la noticia: “*Microsoft August 2025 Patch Tuesday fixes 107 flaws, including a critical wormable GDI+ RCE*”.

Enlace a la noticia: <https://www.bleepingcomputer.com/news/microsoft/microsoft-august-2025-patch-tuesday/>

Breve resumen: El boletín mensual de Microsoft de agosto de 2025 fue uno de los más voluminosos del año, con más de cien vulnerabilidades corregidas en un solo ciclo. Entre ellas, *BleepingComputer* destaca específicamente CVE-2025-53766 por dos motivos: su puntuación de 9.8 CRITICAL y, sobre todo, el hecho de que el componente afectado (GDI+) es invocado de manera transparente por una larguísima lista de procesos del sistema, incluidos servicios que decodifican imágenes en cadenas de procesamiento automáticas (motores de *indexing*, vistas previas, miniaturas, pasarelas de correo). El artículo subraya que esta naturaleza “en cadena” eleva el riesgo de transformar la vulnerabilidad en un vector *wormable* si se descubriera un servicio sistémicamente accesible que la utilice, aunque a fecha de publicación de la noticia Microsoft no había reportado evidencia de explotación activa. La pieza también detalla las recomendaciones operativas habituales: aplicar el parche acumulativo, revisar las políticas de procesamiento automatizado de imágenes en servidores y considerar reglas de EDR para detectar comportamientos anómalos en procesos que carguen `gdiplus.dll`. Sirve como ejemplo claro del modelo de divulgación coordinada de Microsoft (*Patch Tuesday*) y de la importancia de monitorizar los boletines mensuales.

Ficha de noticia 3

CVE a la que se refiere: CVE-2023-51582 (Voltronic Power ViewPower Linux).

Fecha de la noticia: 22 de diciembre de 2023.

Título de la noticia: “*ZDI-23-1887: Voltronic Power ViewPower Pro LinuxMonitorConsole Exposed Dangerous Method Remote Code Execution Vulnerability*”.

Enlace a la noticia: <https://www.zerodayinitiative.com/advisories/ZDI-23-1887/>

Breve resumen: El aviso oficial de *Zero Day Initiative* que dio lugar a CVE-2023-51582 detalla, sin entrar en código de explotación funcional, el fallo descubierto en el componente `LinuxMonitorConsole` del agente Voltronic Power ViewPower (también comercializado bajo otras marcas blancas en el sector de SAI). El aviso describe cómo el servicio expone un método remoto que debería estar reservado a operaciones administrativas internas pero, por una configuración insuficiente del control de acceso, queda alcanzable por cualquier cliente capaz de conectarse al puerto de gestión, lo que se traduce en una ejecución remota de código en el contexto del usuario bajo el que corre el agente —típicamente con privilegios elevados sobre la máquina anfitriona porque controla el SAI físico. Además del detalle técnico, el aviso es relevante porque pone el foco sobre una categoría de *software de gestión de infraestructura*

que recibe mucha menos atención mediática que las grandes plataformas (Windows, macOS, Android), pero que está omnipresente en CPDs e instalaciones industriales. La pieza concluye con la recomendación de actualizar a la última versión del agente y, mientras tanto, restringir mediante *firewall* el acceso al servicio.

Capítulo 7

Conclusiones

Esta práctica ha reforzado mi teoría de que al final, los casos más graves no dependen del error del software, sino del humano. Revisando las noticias del informe anterior, y comparando la gravedad de los casos con los casos de vulnerabilidades, a pesar de ser estas de sistemas críticos, no han tenido un impacto ni comparable a los casos en los que el error ha estado en el factor humano.

Lo que más me ha sorprendido al analizar las tres CVE elegidas es comprobar que un mismo *Base Score* de 9.8 con un vector idéntico esconde realidades muy distintas en cuanto a riesgo real. Sobre el papel, las tres son intercambiables: ataque remoto, sin privilegios, sin interacción, con impacto alto en CIA. En la práctica, sin embargo, una afecta a una librería gráfica omnipresente en cualquier Windows del mundo, otra a un parser RTP de una app de mensajería ya parcheada hace años, y la tercera a un agente de gestión de SAI presente sólo en CPDs concretos. El CVSS dice *lo mismo* de las tres y la respuesta racional de un responsable de seguridad debe ser distinta para cada una. Esto resuena con algo que ya intuía: el CVSS Base es un *punto de partida* útil para filtrar, pero la priorización fina depende de variables que no están en el vector —exposición del activo, criticidad del negocio, existencia de exploit funcional, presencia en KEV— y que sólo se obtienen cruzando varias fuentes.

Otra observación relevante es la importancia de *seguir periódicamente* las publicaciones de NVD, INCIBE-CERT y CISA. La frecuencia con la que aparecen vulnerabilidades críticas en componentes nucleares —ya sea GDI+ en Windows, parsers de protocolos en mensajería, agentes de monitorización en Linux— hace inviable enterarse *a posteriori* de los problemas relevantes; la única respuesta razonable es la suscripción sistemática (boletines, RSS de NVD, listas oficiales del fabricante) y la inclusión del CVE-management como tarea continua del equipo de operaciones. INCIBE-CERT, en particular, es un punto de entrada útil en el contexto español porque traduce, contextualiza y filtra ese flujo para el tejido productivo nacional, y CISA aporta la perspectiva de *explotación real* con el KEV. La existencia de estas fuentes es crucial para que estas vulnerabilidades tengan pocas consecuencias.

Las dificultades han venido sobre todo de la **limitación del buscador del NIST**, ya mencionada en el capítulo 2: filtros que no admiten rangos mayores de 120 días han obligado a trocear la consulta en ventanas de tres meses, repitiéndolas dos veces por ventana (una para *Published Date* y otra para *Last Modified*). En la práctica esto implicó del orden de ocho ejecuciones del buscador para cubrir

un único año natural y un trabajo manual de seguimiento de las ventanas ya recorridas. Una segunda dificultad ha sido distinguir entre *informe primario* (CVE.org), *informe enriquecido* (NVD) y *aviso del fabricante*: aunque los tres apuntan a la misma vulnerabilidad, los datos no siempre coinciden con exactitud (estado del registro, fecha de parcheo, severidad asignada por el CNA frente a la del NIST), por lo que ha sido necesario aprender a contrastar siempre al menos dos fuentes antes de dar por cerrado cualquier dato concreto.

En conjunto, la práctica refuerza una idea sencilla pero importante: el ciclo CVE/CVSS no es burocracia, sino *infraestructura compartida* de la comunidad de seguridad. Saber moverse en él — identificar fuentes oficiales, leer vectores con criterio, distinguir lo crítico de lo cosmético, priorizar con datos— es un componente básico del oficio de cualquier responsable de seguridad de la información.

Bibliografía

- [1] National Institute of Standards and Technology (NIST), *National Vulnerability Database (NVD)* — fuente principal consultada para la identificación, descripción, métricas CVSS y referencias cruzadas de las vulnerabilidades CVE analizadas en esta práctica. [En línea]. Disponible: <https://nvd.nist.gov/>
- [2] National Institute of Standards and Technology (NIST), *CVE-2018-6350 Detail*, National Vulnerability Database. [En línea]. Disponible: <https://nvd.nist.gov/vuln/detail/CVE-2018-6350>
- [3] National Institute of Standards and Technology (NIST), *CVE-2025-53766 Detail*, National Vulnerability Database. [En línea]. Disponible: <https://nvd.nist.gov/vuln/detail/CVE-2025-53766>
- [4] National Institute of Standards and Technology (NIST), *CVE-2023-51582 Detail*, National Vulnerability Database. [En línea]. Disponible: <https://nvd.nist.gov/vuln/detail/CVE-2023-51582>
- [5] MITRE Corporation, *CVE Program*. [En línea]. Disponible: <https://www.cve.org/>
- [6] National Institute of Standards and Technology (NIST), *CVSS v3.1 Calculator*, NVD Vulnerability Metrics. [En línea]. Disponible: <https://nvd.nist.gov/vuln-metrics/cvss>
- [7] FIRST.org, *Common Vulnerability Scoring System SIG*. [En línea]. Disponible: <https://www.first.org/cvss/>
- [8] Cybersecurity and Infrastructure Security Agency (CISA), *Known Exploited Vulnerabilities Catalog*. [En línea]. Disponible: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [9] Instituto Nacional de Ciberseguridad (INCIBE-CERT). [En línea]. Disponible: <https://www.incibe.es/incibe-cert>
- [10] Microsoft Security Response Center (MSRC), *Security Update Guide — CVE-2025-53766*. [En línea]. Disponible: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-53766>

- [11] Trend Micro Zero Day Initiative, *ZDI-23-1887: Voltronic Power ViewPower LinuxMonitorConsole Exposed Dangerous Method RCE*. [En línea]. Disponible: <https://www.zerodayinitiative.com/advisories/ZDI-23-1887/>
- [12] BleepingComputer, *Microsoft August 2025 Patch Tuesday Coverage*. [En línea]. Disponible: <https://www.bleepingcomputer.com/news/microsoft/>
- [13] The Guardian, “A WhatsApp vulnerability allowed spyware to be installed via voice calls”, 14 de mayo de 2019. [En línea]. Disponible: <https://www.theguardian.com/technology/2019/may/14/whatsapp-urges-users-to-upgrade-after-discovering-spyware-vulnerability>
- [14] MITRE Corporation, *CWE-125: Out-of-bounds Read*. [En línea]. Disponible: <https://cwe.mitre.org/data/definitions/125.html>
- [15] MITRE Corporation, *CWE-122: Heap-based Buffer Overflow*. [En línea]. Disponible: <https://cwe.mitre.org/data/definitions/122.html>
- [16] MITRE Corporation, *CWE-749: Exposed Dangerous Method or Function*. [En línea]. Disponible: <https://cwe.mitre.org/data/definitions/749.html>